COMPTE RENDU DU TP3.2 : Attaque d'un système Windows et extraction d'identification

1. Introduction

L'objectif de ce TP est de simuler une attaque réelle sur un environnement Windows en exploitant le service de partage de fichiers **SMB** (Server Message Block). Nous allons passer par les phases de reconnaissance, d'énumération, puis d'exploitation pour obtenir un contrôle total de la cible.

Environnement :

Attaquant : Kali Linux (IP : 192.168.56.30)

Cible : Windows (IP : 192.168.56.20)

1. **Phase de Reconnaissance (Nmap)**

La première étape consiste à identifier les ports ouverts sur la cible.

Commande utilisée : **nmap -sS 192.168.56.20**

```
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=1.20 ms
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=1.42 ms
64 bytes from 192.168.56.20: icmp_seq=6 ttl=128 time=1.51 ms
64 bytes from 192.168.56.20: icmp_seq=7 ttl=128 time=1.33 ms
64 bytes from 192.168.56.20: icmp_seq=8 ttl=128 time=1.17 ms
^C
--- 192.168.56.20 ping statistics ---
8 packets transmitted, 8 received, 0% packet loss, time 7059ms
rtt min/avg/max/mdev = 1.165/1.347/1.700/0.173 ms

┌──(jovanie㉿kali)-[~]
└─$ nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 05:57 +0100
Nmap scan report for 192.168.56.20
Host is up (0.0012s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 08:00:27:9E:11:3C (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 26.22 seconds

┌──(jovanie㉿kali)-[~]
└─$
```

Résultat : Le port 445/tcp (microsoft-ds) est ouvert, confirmant la présence du service SMB.

- Scan de découverte avec la commande: **nmap -p 445 --script smb-os-discovery 192.168.56.20**

```
┌──(jovanie㉿kali)-[~]
└─$ nmap -p 445 --script smb-os-discovery  192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-22 16:49 +0100
Nmap scan report for 192.168.56.20
Host is up (0.00091s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:9E:11:3C (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.40 seconds

┌──(jovanie㉿kali)-[~]
└─$
```

Analyse : Ce scan nous a permis de confirmer la version de l'OS cible et le nom du groupe de travail (Workgroup).

[Insérer ici ta capture d'écran du scan Nmap]*

2. Énumération des Partages (smbclient)

Nous avons tenté de lister les dossiers partagés sans identifiants avec ;

Commande : **smbclient -L //192.168.56.20 –N**

```
┌──(jovanie㉿kali)-[~]
└─$ smbclient -L //192.168.56.20 -N
session setup failed: NT_STATUS_ACCESS_DENIED

┌──(jovanie㉿kali)-[~]
└─$
```

- **Observation** : Une erreur NT_STATUS_ACCESS_DENIED a été retournée.
- **Conclusion** : La cible est correctement configurée pour refuser les connexions anonymes. Il est donc nécessaire de posséder des identifiants valides.

❖ **Simulation d'un cas réaliste** : identifiants faible

Sur la machine cible(Windows) nous avons créé un compte vulnérable avec la commande :

net user supportadmin password123!

```
C:\Windows\system32>net user supportadmin password123! /add
La commande s'est terminée correctement.


C:\Windows\system32>net localgroup administrateur supportadmin /add
L'erreur système 1376 s'est produite.

Le groupe local spécifié n'existe pas.


C:\Windows\system32>net localgroup administrators supportadmin /add
L'erreur système 1376 s'est produite.

Le groupe local spécifié n'existe pas.


C:\Windows\system32>net localgroup Administrateurs supportadmin /add
La commande s'est terminée correctement.


C:\Windows\system32>net user supportadmin
Nom d'utilisateur                            supportadmin
Nom complet
Commentaire
Commentaires utilisateur
Code du pays ou de la région                 000 (Valeur par défaut du système)
Compte : actif                               Oui
Le compte expire                             Jamais

Mot de passe : dernier changmt.              4/26/2026 10:02:23 AM
Le mot de passe expire                       6/7/2026 10:02:23 AM
Le mot de passe modifiable                   4/26/2026 10:02:23 AM
Mot de passe exigé                           Oui
L'utilisateur peut changer de mot de passe   Oui

Stations autorisées                          Tout
Script d'ouverture de session
Profil d'utilisateur
Répertoire de base
Dernier accès                                Jamais
```

3. Test d'Authentification (Metasploit)

Nous avons utilisé le module smb_login pour vérifier les identifiants fournis (testuser / Password123!).

Module: **auxiliary/scanner/smb/smb_login**

Résultat : Après avoir configuré un mot de passe sur la machine Windows, le test a renvoyé :

```
jovanie@kali: ~
Session  Actions  Éditer  Vue  Aide
+ -- --=[ 432 post - 49 encoders - 14 nops - 10 evasion        ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can o
pen an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBpass Password123!
SMBpass => Password123!
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445     - 192.168.56.20:445     - Starting SMB login brutef
orce
[+] 192.168.56.20:445     - 192.168.56.20:445     - Success: '.\testuser:Pass
word123!'
[!] 192.168.56.20:445     - No active DB -- Credential data will not be saved
!
[*] 192.168.56.20:445     - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445     - Bruteforce completed, 1 credential was successful
.
[*] 192.168.56.20:445     - You can open an SMB session with these credential
s and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

5. Exploitation et Prise de Contrôle (PsExec)

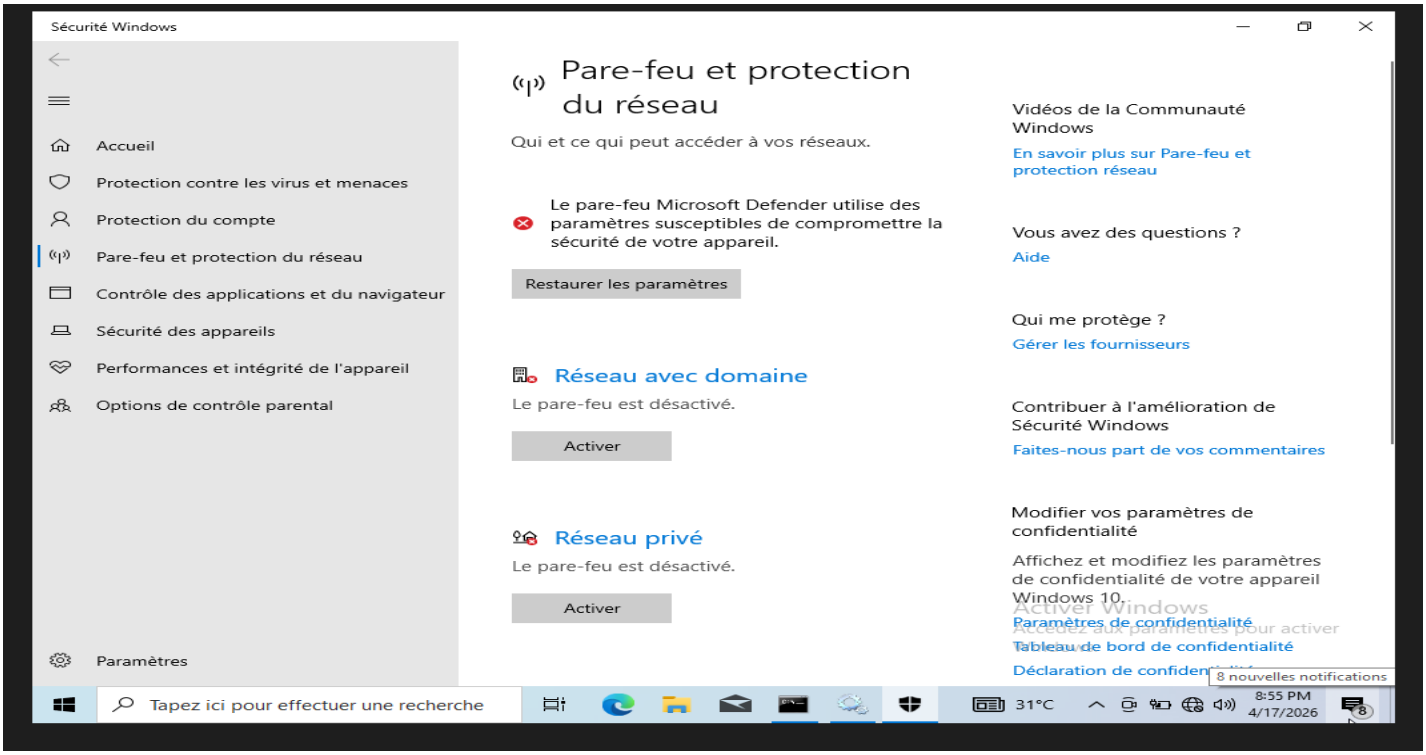
L'étape finale consiste à utiliser l'exploit psexec pour ouvrir une session Meterpreter.

Module: **exploit/Windows/smb/psexec**

Difficultés rencontrées : L'attaque a initialement échoué avec une erreur STATUS_ACCESS_DENIED.

Mesures correctives appliquées sur la cible :

1. Ajout de l'utilisateur au groupe Administrateurs.
2. Désactivation du pare-feu Windows.
3. Ajout de la clé de registre LocalAccountTokenFilterPolicy (valeur 1) pour désactiver la restriction UAC distante.
4. Désactivation de la protection en temps réel de Windows Defender.



6. Post-Exploitation

Une fois la session ouverte, nous avons exécuté les commandes suivantes :

1. getuid : Pour confirmer que nous avons les privilèges SYSTEM.
2. sysinfo : Pour obtenir les détails matériels et logiciels de la cible.
3. hashdump : Pour extraire les empreintes (hashes) des mots de passe des utilisateurs locaux.

7. Conclusion et Recommandations

Ce TP démontre qu'une simple faiblesse d'identifiant (Password123!) couplée à un service SMB exposé peut mener à une compromission totale du système ; les mesures de protection recommandées sont les suivantes :

- **Politique de mots de passe** : Imposer des mots de passe complexes et uniques.
- **Désactivation de SMBv1** : Utiliser uniquement les versions sécurisées du protocole.
- **Principe du moindre privilège** : Ne pas donner de droits d'administrateur aux comptes utilisateurs standards.
- **Surveillance** : Activer l'audit des connexions SMB pour détecter les tentatives de force brute.